Table of Contents

Cisco Catalyst C9300 Switch Hardening Report 2

1. Configuration Overview 2

1.1 General Configuration 2

1.2 Line and Access Configuration 2

1.3 Secure Management Protocols 2

1.4 Logging and Monitoring 3

1.5 Authentication and Encryption 3

1.6 Banners 3

2. Known Vulnerability Mitigation 4

2.1 SSL Certificate Cannot Be Trusted & SSL Self-Signed Certificate 4

2.2 OpenSSH < 9.3p2 Vulnerability 4

2.3 OpenSSH < 9.6 Multiple Vulnerabilities & SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795) 4

2.4 Web Server Uses Basic Authentication Without HTTPS 5

2.5 Web Server Allows Password Auto-Completion 5

2.6 CVE-1999-0524 (ICMP Information Disclosure) 5

2.7 OpenSSH Versions < 7.4, < 7.5, < 7.6, < 7.8, < 8.0, 6.2 < 8.8 5

Cisco Catalyst C9300 Switch Hardening Report

Date: March 21, 2025
Prepared by: Hassan Rhani.
Device: Cisco Catalyst C9300 Switch
Objective: To secure and harden the Cisco C9300 switch by applying best practices and mitigating identified vulnerabilities using standards CIS Benchmark.

1. Configuration Overview

The following configurations have been applied to harden the Cisco C9300 switch. These settings enhance security by restricting unauthorized access, disabling unnecessary services, and implementing secure management practices.

1.1 General Configuration

```
ip domain-name [domain-name]
ip name-server [dns-server-ip]
ntp server [ntp-server-ip]
timezone IST +5 30
crypto key generate rsa modulus 2048
```

1.2 Line and Access Configuration

```
line aux 0
 no exec
 transport input none
 transport output none
 exec-timeout 0 1
 no password

line console 0
 exec-timeout 10

line vty 0 31
 exec-timeout 10
```

1.3 Secure Management Protocols

```
no ip http server
no ip http secure-server
no ip http authentication local

ip ssh time-out 120
ip ssh authentication-retries 5
ip ssh version 2
no ip bootp server

service tcp-keepalives-in
service tcp-keepalives-out
no service pad
```

1.4 Logging and Monitoring

```
archive
 log config
  logging enable
logging buffered 64000
logging console critical
service timestamps debug datetime localtime show-timezone
service timestamps log datetime msec localtime show-timezone
logging source-interface vlan [vlan-id]
login on-success log
login on-failure log
```

1.5 Authentication and Encryption

```
enable secret 0 P@ssw0rd@!@#
service password-encryption
username admin privilege 15 secret 9 P2ssw0rd@!@#
```

1.6 Banners

```
banner exec ^CCCC
 W A R N I N G
**********************************************************************************************************************************
* This system is the property of "". It is for authorized use only.                                                                *
* Unauthorized or improper use of this system may result in administrative disciplinary action and/or civil
charges/criminal penalties. *
* By logging in this system you indicate your awareness and consent to these terms of use.                                          *
* If you agree to the terms stated in this warning.                                                                                  *
**********************************************************************************************************************************
^C

banner login ^C
**********************************************************************
* This Device is the Property of "COMPANY_NAME"                      *
* Unauthorised access is strictly prohibited                         *
**********************************************************************
^C

banner motd ^C
**********************************************************************************************************************************
* This system is the property of "". It is for authorized use only.                                                                *
* Unauthorized or improper use of this system may result in administrative disciplinary action and/or civil
charges/criminal penalties. *
* By logging in this system you indicate your awareness and consent to these terms of use.                                          *
* If you agree to the terms stated in this warning.                                                                                  *
**********************************************************************************************************************************
^C
```

2. Known Vulnerability Mitigation

The following vulnerabilities were identified and mitigated as part of the hardening process. Explanations and applied fixes are provided below.

2.1 SSL Certificate Cannot Be Trusted & SSL Self-Signed Certificate

- **Issue:** Use of a self-signed certificate for HTTPS access.
- **Mitigation:**

```
no ip http secure-server
```

- **Explanation:**
  The HTTPS server has been disabled as the device is managed solely via CLI, and GUI/HTTPS access is not required. Disabling the HTTPS server prevents TLS/SSL handshakes, eliminating the need for a trusted CA-signed certificate. While a self-signed certificate remains in the configuration, it is not used when HTTPS is disabled.
  For CA-signed certificate installation, refer to:
  [Cisco Guide: Configure CA-Signed Certificates]

2.2 OpenSSH < 9.3p2 Vulnerability

- **Issue:** Vulnerable ciphers in OpenSSH implementation.
- **Mitigation:**

```
no ip ssh server algorithm encryption chacha20-poly1305@openssh.com
no ip ssh client algorithm encryption chacha20-poly1305@openssh.com
no ip ssh server algorithm mac hmac-sha2-256-etm@openssh.com
no ip ssh client algorithm mac hmac-sha2-256-etm@openssh.com
no ip ssh server algorithm mac hmac-sha2-512-etm@openssh.com
no ip ssh client algorithm mac hmac-sha2-512-etm@openssh.com
```

- **Explanation:**
  Removed affected encryption and MAC algorithms to mitigate vulnerabilities in OpenSSH versions prior to 9.3p2.

2.3 OpenSSH < 9.6 Multiple Vulnerabilities & SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

- **Issue:** Vulnerable MAC algorithms susceptible to prefix truncation attacks.
- **Mitigation:**

```
ip ssh client algorithm mac hmac-sha2-256 hmac-sha2-512
ip ssh server algorithm mac hmac-sha2-256 hmac-sha2-512
no ip ssh server algorithm encryption chacha20-poly1305@openssh.com
no ip ssh client algorithm encryption chacha20-poly1305@openssh.com
no ip ssh server algorithm mac hmac-sha2-256-etm@openssh.com
no ip ssh client algorithm mac hmac-sha2-256-etm@openssh.com
no ip ssh server algorithm mac hmac-sha2-512-etm@openssh.com
no ip ssh client algorithm mac hmac-sha2-512-etm@openssh.com
```

- **Explanation:**
  Configured secure MAC algorithms (hmac-sha2-256, hmac-sha2-512) without the vulnerable -etm@openssh.com suffix and removed affected ciphers to address CVE-2023-48795.

2.4 Web Server Uses Basic Authentication Without HTTPS

- **Issue:** HTTP server enabled without HTTPS.
- **Mitigation:**

```
no ip http secure-server
```

- **Explanation:**
  Disabled the HTTP server as it is not required for management, eliminating the risk of unencrypted authentication.

2.5 Web Server Allows Password Auto-Completion

- **Issue:** Potential password exposure via auto-completion.
- **Explanation:**
  Per Cisco bug CSCwi89826, IOS-XE devices are not affected by this vulnerability. No further action is required.

2.6 CVE-1999-0524 (ICMP Information Disclosure)

- **Issue:** ICMP allows netmask and timestamp information from arbitrary hosts.
- **Mitigation:**

```
access-list 123 deny icmp any any timestamp-request
access-list 123 deny icmp any any timestamp-reply
access-list 123 permit ip any any
interface [L3-interface]
 ip access-group 123 in
```

- **Explanation:**
  Applied an ACL to deny ICMP timestamp requests and replies, preventing information disclosure. Refer to: Cisco Community: Fix for CVE-1999-0524

2.7 OpenSSH Versions < 7.4, < 7.5, < 7.6, < 7.8, < 8.0, 6.2 < 8.8

- **Issue:** Potential vulnerabilities in older OpenSSH versions.
- **Explanation:**
  The current software version (IOS-XE 17.12.4) is not affected by these vulnerabilities, as confirmed by:
  - Bug CSCvy91615
  - Cisco Software Checker: Link

3. Additional Notes

- **Reference Template:** Cisco Access Lists Guide
- **Software Version:** IOS-XE 17.12.4 (verified as secure against listed OpenSSH vulnerabilities).
- **Recommendations:**
  - Regularly update the switch firmware to address newly discovered vulnerabilities.
  - Review and update passwords periodically to maintain security.